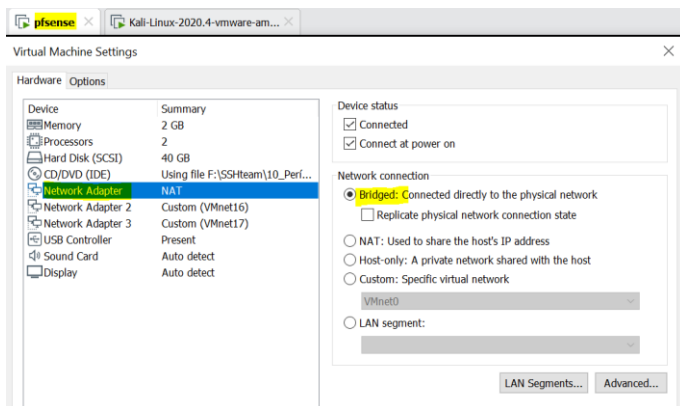


Tarea para SAD05 - pfsense

Apartado 3: Configuración de reglas Iptables

- Permite conexiones entrantes SSH desde la WAN a la LAN.



Cambio la tarjeta NAT a Bridget para estar en red con el real

Pfsense

```
*** Welcome to pfSense 2.4.5-RELEASE-p1 (amd64) on pfSense ***

WAN (wan)      -> em0      -> v4/DHCP4: 192.168.1.232/24
LAN (lan)      -> em1      -> v4: 192.168.100.1/24
OPT1 (opt1)    -> em2      -> v4: 192.168.200.2/24

0) Logout (SSH only)          9) pfTop
1) Assign Interfaces          10) Filter Logs
2) Set interface(s) IP address 11) Restart webConfigurator
3) Reset webConfigurator password 12) PHP shell + pfSense tools
4) Reset to factory defaults  13) Update from console
5) Reboot system              14) Enable Secure Shell (sshd)
6) Halt system                15) Restore recent configuration
7) Ping host                  16) Restart PHP-FPM
8) Shell

Enter an option:
```

PC anfitrión o real

```
Adaptador de LAN inalámbrica Wi-Fi:

Sufijo DNS específico para la conexión. . : lan
Vínculo: dirección IPv6 local. . . : fe80::acf2:54ac:5a5a:af13%17
Dirección IPv4. . . . . : 192.168.1.116
Máscara de subred. . . . . : 255.255.255.0
Puerta de enlace predeterminada. . . . : 192.168.1.1

C:\Users\nuria>
```

Hay que conectarse a la LAN (kali - 192.168.100.100) comprobamos que tiene activo el servicio ssh

```
(kali@kali)-[~]
$ ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host
        valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc pfifo_fast state UP group default qlen 1000
    link/ether 00:0c:29:cd:28:91 brd ff:ff:ff:ff:ff:ff
    inet 192.168.100.100/24 brd 192.168.100.255 scope global dynamic eth0
        valid_lft 7182sec preferred_lft 7182sec
    inet6 fe80::20c:29ff:fecd:2891/64 scope link
        valid_lft forever preferred_lft forever

(kali@kali)-[~]
$ service ssh status
• ssh.service - OpenBSD Secure Shell server
   Loaded: loaded (/lib/systemd/system/ssh.service; disabled; vendor preset: disabled)
   Active: inactive (dead)
     Docs: man:sshd(8)
           man:sshd_config(5)

(kali@kali)-[~]
$ service ssh start

(kali@kali)-[~]
$ service ssh status
• ssh.service - OpenBSD Secure Shell server
   Loaded: loaded (/lib/systemd/system/ssh.service; disabled; vendor preset: disabled)
   Active: active (running) since Wed 2021-03-24 12:13:36 EDT; 21s ago
     Docs: man:sshd(8)
           man:sshd_config(5)
  Process: 1505 ExecStartPre=/usr/sbin/sshd -t (code=exited, status=0/SUCCESS)
 Main PID: 1506 (sshd)
   Tasks: 1 (limit: 2300)
  Memory: 2.1M
   CGroup: /system.slice/ssh.service
           └─1506 sshd: /usr/sbin/sshd -D [listener] 0 of 10-100 startups
```

Sin poner ninguna regla, comprobamos si nos podemos conectar del pfsense a la LAN (kali)

Firewall / Rules / WAN

Floating **WAN** LAN DMZ

Rules (Drag to Change Order)

	States	Protocol	Source	Port	Destination	Port	Gateway	Queue	Schedule	Description	Actions
☐											

Floating **WAN** **LAN** DMZ

Rules (Drag to Change Order)

	States	Protocol	Source	Port	Destination	Port	Gateway	Queue	Schedule	Description	Actions
☒	✓	1 / 486 KiB	*	*	*	LAN Address	80	*	*	Anti-Lockout Rule	⚙️
☐	✓	2 / 53 KiB	IPv4 *	LAN net	*	*	*	*	none	Default allow LAN to any rule	🔗 🛠️ 📄 🗑️
☐	✓	0 / 0 B	IPv6 *	LAN net	*	*	*	*	none	Default allow LAN IPv6 to any rule	🔗 🛠️ 📄 🗑️

```
Enter an option: 8
[2.4.5-RELEASE][root@pfSense.iescomercio.local]/root: ssh kali@192.168.100.100
The authenticity of host '192.168.100.100 (192.168.100.100)' can't be established.
ECDSA key fingerprint is SHA256:W/HiMJfhkvZrzvRf/JTsJHh+T/whnx8c20egkn0X03E.
No matching host key fingerprint found in DNS.
Are you sure you want to continue connecting (yes/no)? yes
Warning: Permanently added '192.168.100.100' (ECDSA) to the list of known hosts.
kali@192.168.100.100's password:
Linux kali 5.9.0-kali1-amd64 #1 SMP Debian 5.9.1-1kali2 (2020-10-29) x86_64

The programs included with the Kali GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Kali GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
Last login: Wed Mar 24 11:47:03 2021 from 192.168.100.1
??(Message from Kali developers)
?
? We have kept /usr/bin/python pointing to Python 2 for backwards
? compatibility. Learn how to change this and avoid this message:
? ? https://www.kali.org/docs/general-use/python3-transition/
?
??(Run "touch ~/.hushlogin" to hide this message)
(kali??kali)-[~]
$
```

SI podemos. ¿Y de la LAN (kali) al pfsense?

```
(kali@kali)-[~]
$ ssh admin@192.168.100.1
ssh: connect to host 192.168.100.1 port 22: Connection timed out
```

NO

Para ello, habilitamos en el menú 14 del pfsense que podamos conectarnos con ssh

```
0) Logout (SSH only)
1) Assign Interfaces
2) Set interface(s) IP address
3) Reset webConfigurator password
4) Reset to factory defaults
5) Reboot system
6) Halt system
7) Ping host
8) Shell
9) pfTop
10) Filter Logs
11) Restart webConfigurator
12) PHP shell + pfSense tools
13) Update from console
14) Enable Secure Shell (sshd)
15) Restore recent configuration
16) Restart PHP-FPM

Enter an option: 14

SSHD is currently disabled. Would you like to enable? [y/n]? y
```

Se ha modificado automáticamente la regla por defecto “Anti-Lockout” de la interface LAN

Floating WAN LAN DMZ											
Rules (Drag to Change Order)											
☐	States	Protocol	Source	Port	Destination	Port	Gateway	Queue	Schedule	Description	Actions
☒	5/1.11 MIB	*	*	*	LAN Address	80 22	*	*		Anti-Lockout Rule	

Desde la LAN (kali) al pfsense

```
(kali@kali)-[~]
└─$ ssh admin@192.168.100.1
The authenticity of host '192.168.100.1 (192.168.100.1)' can't be established.
ED25519 key fingerprint is SHA256:injnTgtIhzt8uXDz02aL8IZF05KL65GhrndI6UfGymI.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '192.168.100.1' (ED25519) to the list of known hosts.
Password for admin@pfSense.iescomercio.local:
VMware Virtual Machine - Netgate Device ID: f2304d78d6ffc0f18138

*** Welcome to pfSense 2.4.5-RELEASE-p1 (amd64) on pfSense ***

WAN (wan)    -> em0      -> v4/DHCP4: 192.168.1.232/24
LAN (lan)    -> em1      -> v4: 192.168.100.1/24
DMZ (opt1)   -> em2      -> v4: 192.168.200.2/24

0) Logout (SSH only)          9) pfTop    IPv6 Configuration Type  None
1) Assign Interfaces          10) Filter Logs
2) Set interface(s) IP address 11) Restart webConfigurator
3) Reset webConfigurator password 12) PHP shell + pfSense tools
4) Reset to factory defaults    13) Update from console
5) Reboot system              14) Disable Secure Shell (sshd)
6) Halt system                15) Restore recent configuration
7) Ping host                  16) Restart PHP-FPM
8) Shell

Enter an option: 1
```

SI

¿Comprobamos si desde el pc anfitrión o real nos podemos conectar al pfsense?

```
C:\Users\nuria>ssh admin@192.168.1.232
ssh: connect to host 192.168.1.232 port 22: Connection timed out
```

NO

Añadimos una regla a la interface WAN

Floating WAN LAN DMZ											
Rules (Drag to Change Order)											
☐	States	Protocol	Source	Port	Destination	Port	Gateway	Queue	Schedule	Description	Actions
☐	☒	0/0 B	IPv4 TCP	*	*	WAN net 22 (SSH)	*	none		ssh a wan	

Y ahora comprobamos que del pc anfitrión o real al pfsense nos podemos conectar

```
C:\Users\nuria>ssh admin@192.168.1.232
The authenticity of host '192.168.1.232 (192.168.1.232)' can't be established.
ED25519 key fingerprint is SHA256:injnTgtIhzt8uXDz02aL8IZF05KL65GhrndI6UfGymI.
Are you sure you want to continue connecting (yes/no)? yes
Warning: Permanently added '192.168.1.232' (ED25519) to the list of known hosts.
Password for admin@pfSense.iescomercio.local:
VMware Virtual Machine - Netgate Device ID: f2304d78d6ffc0f18138

*** Welcome to pfSense 2.4.5-RELEASE-p1 (amd64) on pfSense ***

WAN (wan)    -> em0      -> v4/DHCP4: 192.168.1.232/24
LAN (lan)    -> em1      -> v4: 192.168.100.1/24
DMZ (opt1)   -> em2      -> v4: 192.168.200.2/24

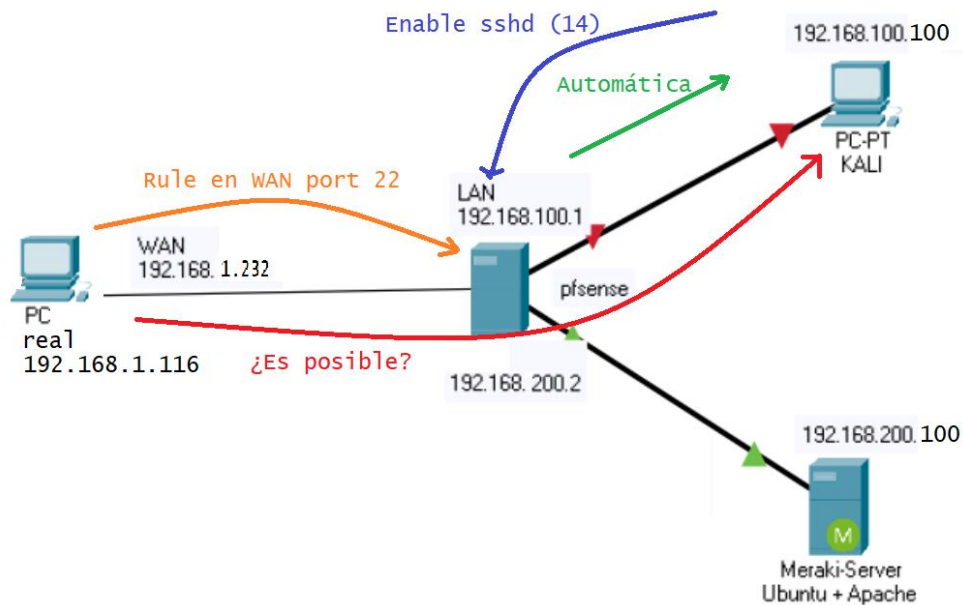
0) Logout (SSH only)          9) pfTop
1) Assign Interfaces          10) Filter Logs
2) Set interface(s) IP address 11) Restart webConfigurator
3) Reset webConfigurator password 12) PHP shell + pfSense tools
4) Reset to factory defaults    13) Update from console
5) Reboot system              14) Disable Secure Shell (sshd)
6) Halt system                15) Restore recent configuration
7) Ping host                  16) Restart PHP-FPM
8) Shell

Enter an option: 0

Connection to 192.168.1.232 closed.
C:\Users\nuria>
```

SI

¿Y a la LAN nos podemos conectar desde el real?



¿Hay alguna forma de redirigir el tráfico del servicio SSH que entra por 22 de la IP pública a la LAN?

Haciendo NAT

Firewall / NAT / Port Forward / Edit

Edit Redirect Entry

Disabled ☐ Disable this rule

No RDR (NOT) ☐ Disable redirection for traffic matching this rule
This option is rarely needed. Don't use this without thorough knowledge of the implications.

Interface WAN
Choose which interface this rule applies to. In most cases "WAN" is specified.

Protocol TCP
Choose which protocol this rule should match. In most cases "TCP" is specified.

Source [Display Advanced](#)

Destination ☐ Invert match. WAN address
Type Address/mask

Destination port range Other 22 Other 22
From port Custom To port Custom
Specify the port or port range for the destination of the packet for this mapping. The 'to' field may be left empty if only mapping a single port.

Redirect target IP 192.168.100.100
Enter the internal IP address of the server on which to map the ports.
e.g.: 192.168.1.12

Redirect target port Other 22
Port Custom
Specify the port on the machine with the IP address entered above. In case of a port range, specify the beginning port of the range (the end port will be calculated automatically).
This is usually identical to the "From port" above.

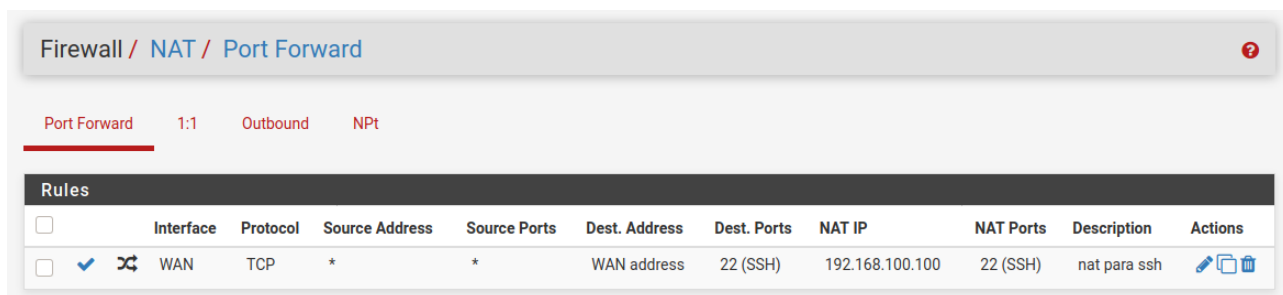
Description nat para ssh
A description may be entered here for administrative reference (not parsed).

No XMLRPC Sync ☐ Do not automatically sync to other CARP members
This prevents the rule on Master from automatically syncing to other CARP members. This does NOT prevent the rule from being overwritten on Slave.

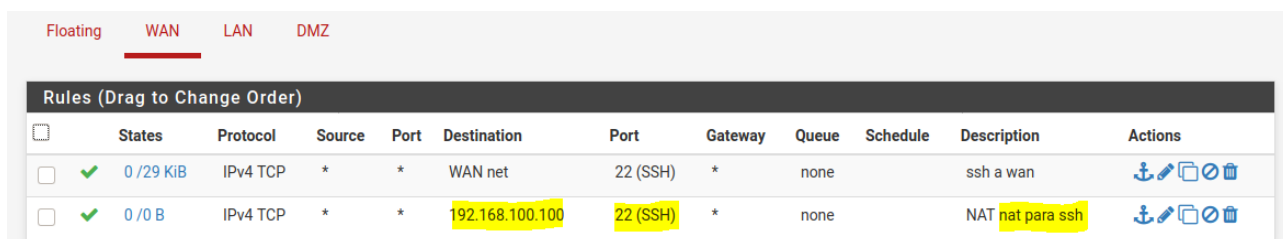
NAT reflection Use system default

Filter rule association Add associated filter rule
The "pass" selection does not work properly with Multi-WAN. It will only work on an interface containing the default gateway.

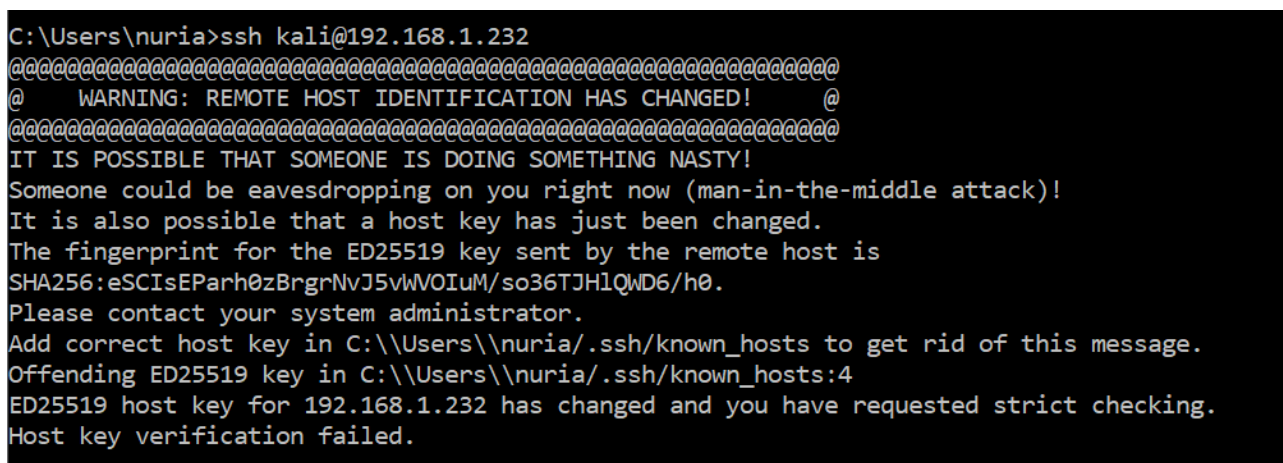
[Save](#)



Vemos que se ha añadido automáticamente la regla en WAN



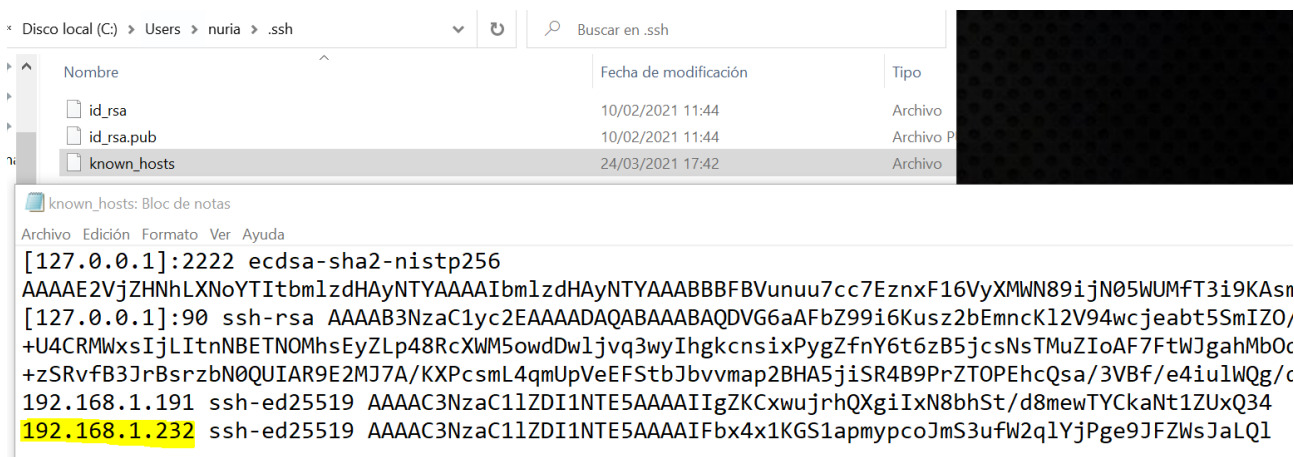
Probamos a conectarnos a la IP pública y ver si nos redirige a la LAN



Nos da un posible **man-in-the-middle attack**

Nos dice que la huella digital de la clave enviada por el host remoto no es correcta.

Podemos agregar la clave de host correcta en C:\Users\nuria\.ssh\known_hosts



O eliminamos la línea para que nos diga que la autenticación no está establecida y aceptemos la nueva huella

```

C:\Users\nuria>ssh kali@192.168.1.232
The authenticity of host '192.168.1.232 (192.168.1.232)' can't be established.
ECDSA key fingerprint is SHA256:W/HiMJfhkvZrzvRf/JTsJHh+T/whnx8c20egkn0X03E.
Are you sure you want to continue connecting (yes/no)? yes
Warning: Permanently added '192.168.1.232' (ECDSA) to the list of known hosts.
kali@192.168.1.232's password:
Linux kali 5.9.0-kali1-amd64 #1 SMP Debian 5.9.1-1kali2 (2020-10-29) x86_64

The programs included with the Kali GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Kali GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
Last login: Wed Mar 24 12:20:17 2021 from 192.168.100.1
Linux kali 5.9.0-kali1-amd64 #1 SMP Debian 5.9.1-1kali2 (2020-10-29) x86_64

The programs included with the Kali GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Kali GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
Last login: Wed Mar 24 12:20:17 2021 from 192.168.100.1
(Message from Kali developers)

We have kept /usr/bin/python pointing to Python 2 for backwards
compatibility. Learn how to change this and avoid this message:
https://www.kali.org/docs/general-use/python3-transition/

(Run "touch ~/.hushlogin" to hide this message)
(kali@kali)-[~]
$

```

```

(kali@kali)-[~]
$ ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host
        valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc pfifo_fast state UP group default qlen 1000
    link/ether 00:0c:29:cd:28:91 brd ff:ff:ff:ff:ff:ff
    inet 192.168.100.100/24 brd 192.168.100.255 scope global dynamic eth0
        valid_lft 1452sec preferred_lft 1452sec
    inet6 fe80::20c:29ff:fe2d:2891/64 scope link
        valid_lft forever preferred_lft forever

```

Nos hemos conectado desde la red exterior a un pc de la LAN con el servicio SSH.

